

Vulnerability Assessment

A **Vulnerability Assessment** aims to identify and categorize risks for security weaknesses related to assets within an environment. It is important to note that **there is little to no manual exploitation during a vulnerability assessment**. A vulnerability assessment also provides remediation steps to fix the issues.

The purpose of a **Vulnerability Assessment** is to understand, identify, and categorize the risk for the more apparent issues present in an environment without actually exploiting them to gain further access. Depending on the scope of the assessment, some customers may ask us to validate as many vulnerabilities as possible by performing minimally invasive exploitation to confirm the scanner findings and rule out false positives. Other customers will ask for a report of all findings identified by the scanner. As with any assessment, it is essential to clarify the scope and intent of the vulnerability assessment before starting. Vulnerability management is vital to help organizations identify the weak points in their assets, understand the risk level, and calculate and prioritize remediation efforts.

It is also important to note that organizations should always test substantial patches before pushing them out into their environment to prevent disruptions.

Methodology

Below is a sample vulnerability assessment methodology that most organizations could follow and find success with. Methodologies may vary slightly from organization to organization, but this chart covers the main steps, from identifying assets to creating a remediation plan.

8 Steps To Performing A Network Vulnerability Assessment



1. Conduct Risk Identification And Analysis

Identify all assets that are a part of an information system in a company. With a complete list of all IT equipment, companies can start assigning risks to each asset in order to account for most situations that may arise.



2. Develop Vulnerability Scanning Policies

The policy or a procedure should have an official owner that is in responsible for everything that is written inside. The policy should also be approved by upper management before taking effect.



3. Identify The Type Of Scans

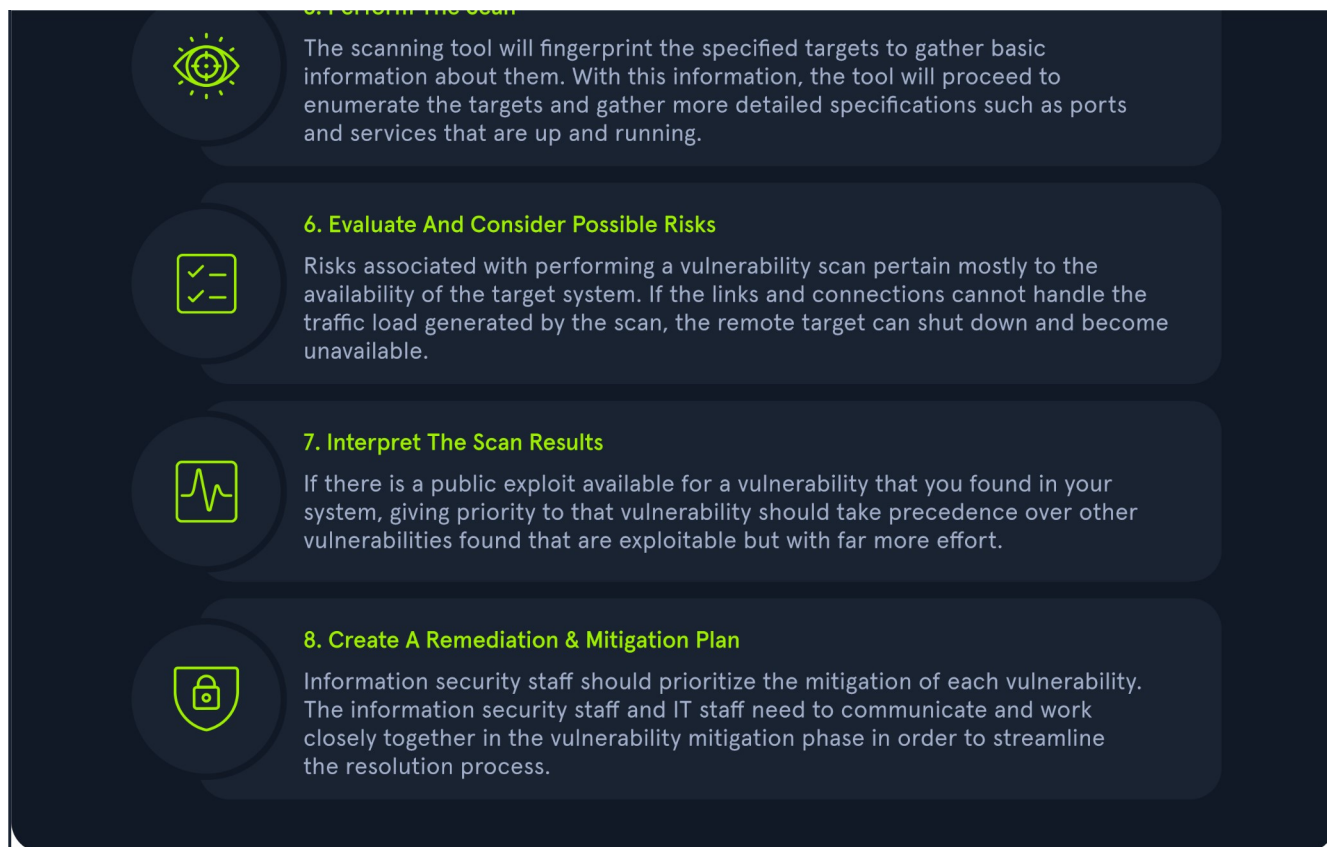
Depending on the software that is running on the system you need to scan and secure, you need to determine the type of scan to be performed in order to get the most benefit. Types of scans include network, host based, wireless based, and applications.



4. Configure The Scan

To configure a vulnerability scan you must: add a list of target IPs, define port ranges and protocols, define the targets, and set up the aggressiveness of the scan, time, and notifications.

5. Perform The Scan



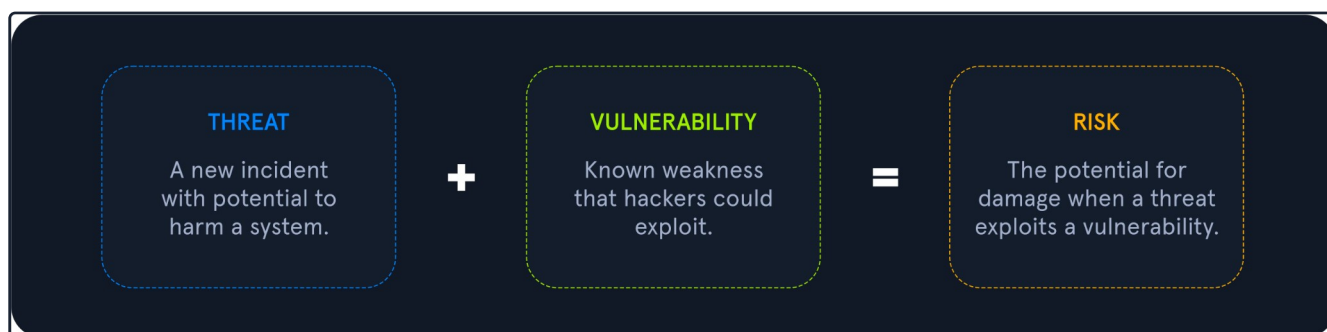
Adapted from the original graphic found [here](#).

Understanding Key Terms

Before we go any further, let's identify some key terms that any IT or Infosec professional should understand and be able to explain clearly.

Vulnerability

A **Vulnerability** is a weakness or bug in an organization's environment, including applications, networks, and infrastructure, that opens up the possibility of threats from external actors. Vulnerabilities can be registered through MITRE's [Common Vulnerability Exposure database](#) and receive a [Common Vulnerability Scoring System \(CVSS\)](#) score to determine severity. This scoring system is frequently used as a standard for companies and governments looking to calculate accurate and consistent severity scores for their systems' vulnerabilities. Scoring vulnerabilities in this way helps prioritize resources and determine how to respond to a given threat. Scores are calculated using metrics such as the type of attack vector (network, adjacent, local, physical), the attack complexity, privileges required, whether or not the attack requires user interaction, and the impact of successful exploitation on an organization's confidentiality, integrity, and availability of data. Scores can range from 0 to 10, depending on these metrics.



For example, SQL injection is considered a vulnerability since an attacker could leverage queries to extract data from an organization's database. This attack would have a higher CVSS score rating if it could be performed without authentication over the internet than if an attacker needed authenticated access to the internal network and separate authentication to the target application.

These types of things must be considered for all vulnerabilities we encounter.

Threat

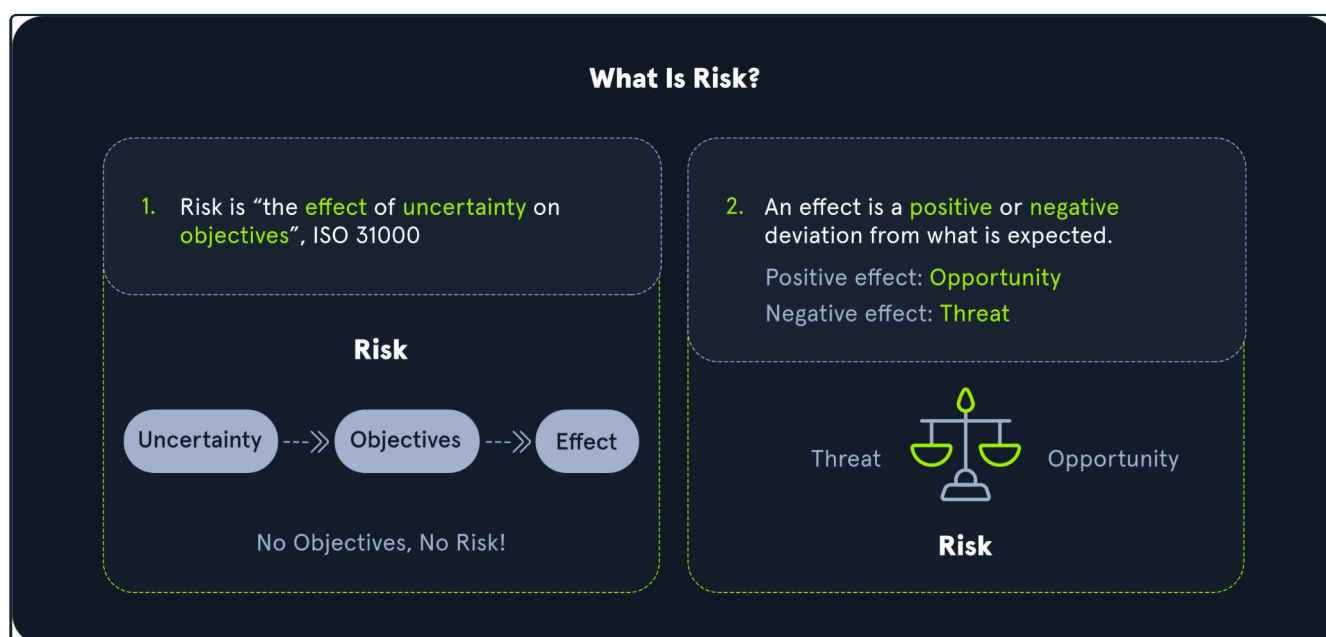
A **Threat** is a process that amplifies the potential of an adverse event, such as a threat actor exploiting a vulnerability. Some vulnerabilities raise more threat concerns over others due to the probability of the vulnerability being exploited. For example, the higher the reward of the outcome and ease of exploitation, the more likely the issue would be exploited by threat actors.

Exploit

An **Exploit** is any code or resources that can be used to take advantage of an asset's weakness. Many exploits are available through open-source platforms such as [Exploitdb](#) or [the Rapid7 Vulnerability and Exploit Database](#). We will often see exploit code hosted on sites such as GitHub and GitLab as well.

Risk

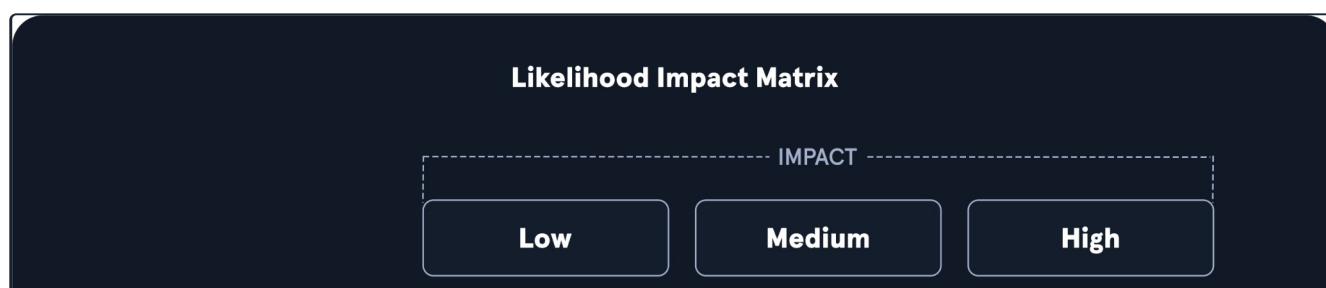
Risk is the possibility of assets or data being harmed or destroyed by threat actors.



To differentiate the three, we can think of it as follows:

- **Risk**: something bad that could happen
- **Threat**: something bad that is happening
- **Vulnerabilities**: weaknesses that could lead to a threat

Vulnerabilities, Threats, and Exploits all play a part in measuring the level of risk in weaknesses by determining the likelihood and impact. For example, vulnerabilities that have reliable exploit code and are likely to be used to gain access to an organization's network would significantly raise the risk of an issue due to the impact. If an attacker had access to the internal network, they could potentially view, edit, or delete sensitive documents crucial for business operations. We can use a qualitative risk matrix to measure risk based on likelihood and impact with the table shown below.



LIKELIHOOD	High	Medium Risk (3)	High Risk (4)	Highest Risk (5)
	Medium	Low Risk (2)	Medium Risk (3)	High Risk (4)
	Low	Lowest Risk (1)	Low Risk (2)	Medium Risk (3)

In this example, we can see that a vulnerability with a low likelihood of occurring and low impact would be the lowest risk level, while a vulnerability with a high likelihood of being exploited and the highest impact on an organization would represent the highest risk and would want to be prioritized for remediation.

Asset Management

When an organization of any kind, in any industry, and of any size needs to plan their cybersecurity strategy, they should start by creating an inventory of their **data assets**. If you want to protect something, you must first know what you are protecting! Once assets have been inventoried, then you can start the process of **asset management**. This is a key concept in defensive security.

Asset Inventory

Asset inventory is a critical component of vulnerability management. An organization needs to understand what assets are in its network to provide the proper protection and set up appropriate defenses. The asset inventory should include information technology, operational technology, physical, software, mobile, and development assets. Organizations can utilize asset management tools to keep track of assets. The assets should have data classifications to ensure adequate security and access controls.

Application and System Inventory

An organization should create a thorough and complete inventory of data assets for proper asset management for defensive security. Data assets include:

- All data stored on-premises. HDDs and SSDs in endpoints (PCs and mobile devices), HDDs & SSDs in servers, external drives in the local network, optical media (DVDs, Blu-ray discs, CDs), flash media (USB sticks, SD cards). Legacy technology may include floppy disks, ZIP drives (a relic from the 1990s), and tape drives.
- All of the data storage that their cloud provider possesses. [Amazon Web Services \(AWS\)](#), [Google Cloud Platform \(GCP\)](#), and [Microsoft Azure](#) are some of the most popular cloud providers, but there are many more. Sometimes corporate networks are "multi-cloud," meaning they have more than one cloud provider. A company's cloud provider will provide tools that can be used to inventory all of the data stored by that particular cloud provider.
- All data stored within various **Software-as-a-Service (SaaS)** applications. This data is also "in the cloud" but might not all be within the scope of a corporate cloud provider account. These are often consumer services or the "business" version of those services. Think of online services such as [Google Drive](#), [Dropbox](#), [Microsoft Teams](#), [Apple iCloud](#), [Adobe Creative Suite](#), [Microsoft Office 365](#), [Google Docs](#), and the list goes on.
- All of the applications a company needs to use to conduct their usual operation and business. Including applications that are deployed locally and applications that are deployed through the cloud or are otherwise Software-as-a-Service.
- All of a company's on-premises computer networking devices. These include but aren't limited to [routers](#), [firewalls](#), [hubs](#), [switches](#), dedicated [intrusion detection and prevention systems \(IDS/IPS\)](#), [data loss prevention \(DLP\)](#) systems, and so on.

All of these assets are very important. A threat actor or any other sort of risk to any of these assets can do significant damage to a company's information security and ability to operate day by day. An organization needs to take its time to assess everything and be careful not to miss a single data asset, or they won't be able to protect it.

Organizations frequently add or remove computers, data storage, cloud server capacity, or other data assets. Whenever data assets are added or removed, this must be thoroughly noted in the [data asset inventory](#).

Onwards

Next, we'll discuss some key standards that organizations may be subject to or choose to follow to standardize their approach to risk and vulnerability management.

[← Previous](#)[Next →](#)[✔ Mark Complete & Next](#)

Table of Contents

Security Assessments

[Security Assessments](#)[Vulnerability Assessment](#)[Assessment Standards](#)

Vulnerability Scoring and Reporting

[Common Vulnerability Scoring System \(CVSS\)](#)[Common Vulnerabilities and Exposures \(CVE\)](#)

Nessus

[Vulnerability Scanning Overview](#)[Getting Started with Nessus](#)[Nessus Scan](#)[Advanced Settings](#)[Working with Nessus Scan Output](#)[Scanning Issues](#)[📦 Nessus Skills Assessment](#)

OpenVAS

[Getting Started with OpenVAS](#)[OpenVAS Scan](#)[Exporting The Results](#)[📦 OpenVAS Skills Assessment](#)

Reporting

[Reporting](#)

My Workstation

O F F L I N E

▶ Start Instance

∞ / 1 spawns left